

# Ninjascode IT Security Policy

*Internal policy document. Applies to all staff and contractors.*

## 1. Authentication

All company accounts must use multi-factor authentication. Authenticator applications are permitted; SMS codes are not.

Passwords must be at least 14 characters long and are rotated every 180 days. Reuse of any of the previous 5 passwords is blocked by the identity provider.

Shared service accounts are prohibited. Every automated system must authenticate with its own named credential stored in the company secret manager.

## 2. Devices and Data Handling

Laptops must have full disk encryption enabled before any company data is copied onto them. BitLocker and FileVault are the only approved implementations.

Customer data classified as confidential may not be stored on personal devices, personal cloud storage, or removable media.

Production database exports must be encrypted with AES-256 and are deleted automatically after 30 days.

## 3. Incident Response

Suspected security incidents must be reported to the security channel within 30 minutes of discovery. Reporting is never penalised, even when the report turns out to be a false alarm.

The security team acknowledges every report within 1 hour and provides an initial severity classification within 4 hours.

Critical incidents require a written post-mortem within 5 working days. Post-mortems are blameless and stored in the engineering wiki.

## 4. Remote and Network Access

Access to internal systems from outside the office requires the company VPN. Split tunnelling is disabled.

Public Wi-Fi may only be used over the VPN. Connecting to production servers from public networks is forbidden.

VPN sessions time out after 12 hours of continuous connection and must be re-authenticated.